

Jeremiah Grossman

Venture capitalist (Grossman Ventures <https://grossman.vc>), Internet protector and industry creator. Founded WhiteHat Security & Bit Discovery. BJJ Black Belt.

MONDAY, NOVEMBER 29, 2010

Calling all security researchers! Submit your new 2010 Web Hacking Techniques

Update 01.03.2011: [Voting has begun!](#)

Update: [Prize information](#)

Each year the web security community produces a stunning amount of new hacking techniques documented in white papers, blog posts, magazine articles, mailing list emails, etc. Within the thousands of pages are the latest ways to attack websites, web browsers, web proxies, and so on. We are NOT talking about individual vulnerabilities with CVE numbers, nor any particular system compromise, but the actual new methods of Web-based attack. To keep track of all these discoveries and encourage information sharing, the **Top Web Hacking Techniques** acts as both a centralized knowledge base and a way to recognize researchers who contribute excellent work.

The selection process for 2010 will be a little different. Last year in [2009](#), where over 80 new attack techniques were recorded, the winners were selected solely by a panel of distinguished security experts. This year we'd like you, the Web security community, to have the opportunity to vote for your favorite research. From the voting results the most popular 15 entries will be those judged by our panel of experts on the basis of novelty, impact, and overall pervasiveness to decide the **Top Ten Web Hacking Techniques of 2010**. Researchers topping the 2010 list may expect to receive praise amongst their peers as have those in past years ([2006](#), [2007](#), [2008](#), and [2009](#)). Right now I'm working on a really cool set of prizes for #1.

Then at [IT-Defense 2011](#) (Feb.) it will be my great honor to introduce each of the top ten during my "Top Ten Web Hacking Techniques of the Year (2011)" presentations. Each technique will be described in technical detail for how they function, what they can do, to whom, and how best to defend against them. The audience will get an opportunity to better understand the newest Web-based attacks believed most likely to be used against us in the future.

To make all this happen we are going to need a lot of help from the community. At the bottom of this post will be the living master list of everything recorded. If anything is missing please comment containing the link to the research. Or maybe you think something should not be on the list. That's cool, but please explain why. While clearly not every technique is as powerful as another, please make every effort to include them anyway. Nothing should be considered too insignificant. Sometimes several issues can be combined for amazingly effective techniques.

Thank you!



BIO

Jeremiah Grossman brings 20+ years of experience in Computer Security and has become one of the most recognizable and world-renowned cybersecurity experts in the industry, coining several of the original hacking terms commonly used around the world today. Early in his career, Jeremiah was known as "The Hacker Yahoo" which led to his role as the company's Information Security Officer. Jeremiah founded WhiteHat Security (now Synopsis), and served as Chief of Security Strategy for SentinelOne which was the highest-valued cybersecurity IPO in history. Most recently, Jeremiah was the founder & CEO of Bit Discovery, which was acquired by Tenable in 2022. He also serves as a company advisor and board member to several tech startups. In his spare time, Jeremiah does Brazilian Jiu-Jitsu and is passionate about classic cars. He recently opened Toybox, a luxury car club in Boise, Idaho.

LINKS

[Jeremiah Grossman](#)

[Twitter](#)

[Facebook](#)

[LinkedIn](#)

[Grossman Ventures](#)

SUBSCRIBE

Posts

Comments

Prizes:

1) OWASP Conference Pass

2) Autographed copies by the authors of "Hacking: The Next Generation", "Hacking Exposed Web Applications 3rd Ed", "24 Deadly Sins of Software Security", "XSS Attacks: Cross Site Scripting Exploits and Defense", "Foundations of Security", "Hacking Web Services", "Web 2.0 Security", "Web Application Obfuscation", "Seven Deadliest Web Application Attacks", "ModSecurity Handbook", "Apache Security", "The Web Application Hacker's Handbook", "SQL Injection Attacks and Defenses", "Detecting Malice", and "Web Security Testing Cookbook."

3) BlackHat USA 2011 Conference Pass

The Complete List of Attack Techniques

1. Evercookie
2. Hacking Auto-Complete (Safari v1, Safari v2 TabHack, Firefox, Internet Explorer)
3. Cookie Eviction
4. Converting unimplementable Cookie-based XSS to a persistent attack
5. phpwn: Attack on PHP sessions and random numbers
6. NAT Pinning: Penetrating routers and firewalls from a web page (forcing router to port forward)
7. Mapping a web browser to GPS coordinates via router XSS + Google Location Services without prompting the user
8. XSHM Mark 2
9. MitM DNS Rebinding SSL/TLS Wildcards and XSS
10. Using Cookies For Selective DoS and State Detection
11. Quick Proxy Detection
12. Flash Camera and Mic Remember Function and XSS
13. Improving HTTPS Side Channel Attacks
14. Side Channel Attacks in SSL
15. Turning XSS into Clickjacking
16. Bypassing CSRF protections with ClickJacking and HTTP Parameter Pollution
17. CSS History Hack In Firefox Without JavaScript for Intranet Portscanning
18. Popup & Focus URL Hijacking
19. Hacking Facebook with HTML5
20. Stealing entire Auto-Complete data in Google Chrome
21. Chrome and Safari users open to stealth HTML5 AppCache attack
22. DNS Rebinding on Java Applets
23. Strokejacking
24. The curse of inverse strokejacking
25. Re-visiting JAVA De-serialization: It can't get any simpler than this !!
26. Fooling B64_Encode(Payload) on WAFs and filters
27. MySQL Stacked Queries with SQL Injection...sort of
28. A Twitter DomXss, a wrong fix and something more
29. Get Internal Network Information with Java Applets
30. Java DSN Rebinding + Java Same IP Policy - The Internet Mayhem
31. Java Applet Same IP Host Access
32. ASP.NET 'Padding Oracle' Crypto Attack
33. Posting raw XML cross-domain

34. Generic cross-browser cross-domain theft
35. One vector to rule them all
36. HTTP POST DoS
37. Penetrating Intranets through Adobe Flex Applications
38. No Alnum JavaScript (cheat sheet, jjencode demo)
39. Attacking HTTPS with Cache Injection
40. Tapjacking: owning smartphone browsers
41. Breaking into a WPA network with a webpage
42. XSS-Track: How to quietly track a whole website through single XSS
43. Next Generation Clickjacking
44. XSSing client-side dynamic HTML includes by hiding HTML inside images and more
45. Stroke triggered XSS and StrokeJacking
46. Internal Port Scanning via Crystal Reports
47. Lost in Translation (ASP's HomoXSSuality)
48. Cross Site URL Hijacking by using Error Object in Mozilla Firefox
49. JavaSnoop
50. IIS5.1 Directory Authentication Bypass by using "\$I30:\$Index_Allocation"
51. Universal XSS in IE8
52. padding oracle web attack (poet, Padbuster, demo)
53. IIS6/ASP & file upload for fun and profit
54. Google Chrome HTTP AUTH Dialog Spoofing through Realm Manipulation
55. NoScript Bypass - "Reflective XSS" through Union SQL Poisoning Trick
56. Persistent Cross Interface Attacks
57. Port Scanning with HTML5 and JS-Recon
58. Performing DDoS attacks with HTML5 Cross Origin Requests & WebWorkers
59. Cracking hashes in the JavaScript cloud with Ravan
60. Will it Blend?
61. Stored XSS Vulnerability @ Amazon
62. Poisoning proxy caches using Java/Flash/Web Sockets
63. How to Conceal XSS Injection in HTML5
64. Expanding the Attack Surface
65. Chronofeit Phishing
66. Non-Obvious (Crypto) Bugs by Example
67. SQLi filter evasion cheat sheet (MySQL)
68. Tabnabbing: A New Type of Phishing Attack
69. UI Redressing: Attacks and Countermeasures Revisited

Posted by [Jeremiah Grossman](#) at [10:37 AM](#)

55 comments:

Unknown said...



I like GDS's adobe flex apps hacks:
<http://www.gdssecurity.com/l/b/2010/03/17/penetrating-intranets-through-adobe-flex-applications/>

[November 29, 2010 at 12:21 PM](#)

Jeremiah Grossman said...



really good one, thanks romain. added #37

[November 29, 2010 at 5:07 PM](#)

Billy said...

How about Nitesh's recent posts?

<https://blogs.sans.org/appsecstreetfighter/2010/11/29/ui-spoofing-safari-iphone/>

<https://blogs.sans.org/appsecstreetfighter/2010/11/08/insecure-handling-url-schemes-apples-ios/>

November 29, 2010 at 6:10 PM

Unknown said...



<http://blog.kotowicz.net/2010/11/xss-track-how-to-quietly-track-whole.html> xss-track, my humble addition to the list.

November 29, 2010 at 11:23 PM

lava said...

Next Generation Clickjacking by Paul Stone is an excellent one:
<http://contextis.co.uk/resources/white-papers/clickjacking/>

Perhaps you had considered these already but just in case:

1) <http://blog.andlabs.org/2010/08/xssing-client-side-dynamic-html.html>

2) http://blog.andlabs.org/2010/04/stroke-triggered-xss-and-strokejacking_o6.html

November 30, 2010 at 7:25 AM

Jeremiah Grossman said...



@Krzysztof thanks for the submission. added #42.

@lava solid, thanks. added #43 - #45.

November 30, 2010 at 8:18 AM

reed said...

I liked the recent exploit for CakePHP:
<http://seclists.org/fulldisclosure/2010/Nov/148>

It's one of the first public examples of a new attack category against PHP.

November 30, 2010 at 2:56 PM

Jeremiah Grossman said...



@reed: do you have a link to the core issue that explains the "new attack category against PHP"?

December 1, 2010 at 9:30 AM

albino said...

When will the voting start/submissions close? I have an as-yet unfinished attack that could still use some polish before I publish it...

December 1, 2010 at 10:21 AM

Jeremiah Grossman said...



@albino: Dec 31. :) Voting will commence shortly thereafter. Tight deadlines for the Feb presentations.

December 1, 2010 at 10:23 AM

Jason said...

Simple, but extremely effective. Not particularly novel, but a powerful combination of effective conventional malware and modern delivery mechanics via persistent script injection -- the return of tweaked malware (i.e. ASPRox) to the world demands attention.

Additionally, I particularly appreciated the fact that I saw strains of ASPRox [reincarnated] in which part of the payload was double-encoded to evade detection.

December 1, 2010 at 7:59 PM

Soroush said...

Please check if it is legit.:

ASP's HomoXSSuality:

<http://hackademix.net/2010/08/17/lost-in-translation-asps-homoxssuality/>

and

<http://soroush.secproject.com/blog/2010/08/noscript-new-bypass-method-by-unicode-in-asp/>

December 2, 2010 at 3:53 AM

Jeremiah Grossman said...



@Jason: As cool and powerful as ASPRox might be, I'm looking for some level of novelty, oh and relative primarily to the Web in some way. I don't think this makes the cut.

@Soroush: HomoXSSuality, that's right, excellent work. #47

December 2, 2010 at 7:12 AM

Soroush said...

Please check if this one is legit. as well:

Cross Site Request Forgery (CSRF) PoC Template (in Javascript)

<https://code.google.com/p/csrf-poc-template-by-js/>

December 3, 2010 at 1:39 AM

Soroush said...

Although you've said to not post CVE or website issues, there are something that never will be fixed or suggest some methods. I can see some of them in the selected techniques. Please check this out as well:

IIS5.1 Directory Authentication Bypass by using
":\$I3o:\$Index_Allocation"

http://irsdl.wordpress.com/2010/07/01/iis5-1-directory-authentication-bypass-by-using-i3oindex_allocation/

December 3, 2010 at 2:28 AM

Jeremiah Grossman said...



@Soroush: tools are cool, but csrf-poc-template-by-js doesn't appear to have a new technique involved. Secondly, would you consider the "IIS5.1 Directory Authentication Bypass" as containing a new filter-evasion technique in there? Something that might apply elsewhere?

December 3, 2010 at 9:23 AM

Soroush said...

You are right about that tool which only makes csrf easier. I only have 1 thing to say about using

Folder:\$I3o:\$Index_Allocation:

I couldn't find any other source that use the same technique to open a directory in win.NTFS. As all of the windows directories are accessible by this technique, it can even bypass some other folder's protection for example in file uploading and so on. I also had written a trick by using similar ADS in the last bullet of section 4 in:

<http://soroush.secproject.com/downloadable/Improve%20File%20Uploaders%E2%80%99%20Protections.pdf>

Now, it's still up to you. I just wanted to keep this in the list if it is really related.

[December 3, 2010 at 10:49 AM](#)

Jeremiah Grossman said...



@Soroush: convincing enough. added #50

[December 3, 2010 at 12:09 PM](#)

Soroush Dalili said...

I found another method for using :\$I3o:\$Index_Allocation that I cannot release it now ;) But, yes, it can still be dangerous!!!

[December 9, 2010 at 12:54 PM](#)

ydinoul said...

Padding oracles!! my top 1, actual new method, powerful, high impact, most web dev platforms affected, remote IIS in 2010, JSF, RoR and lots of apps. Thumbs up to all the remote server attcks! too much client side stuff in the list is the same than years ago with a little change.

[December 9, 2010 at 6:48 PM](#)

singular said...

@ydinoul: I second that.

It's not just ASP.NET. Jeremiah, you should list the paper.

[December 10, 2010 at 2:39 AM](#)

Jeremiah Grossman said...



@ydinoul: would much appreciate a link to the best source of information on padding oracles. would be happy to add it.

[December 10, 2010 at 7:04 AM](#)

ydinoul said...

oki JG! some padding oracle web attack links:

the POET stuff:

<http://netifera.com/research/>

paper:

http://usenix.org/events/woot10/tech/full_papers/Rizzo.pdf

Padbuster

<http://www.gdssecurity.com/l/b/2010/09/14/automated-padding-oracle-attacks-with-padbuster/>

demo against dotnetnuke:

http://www.youtube.com/watch?v=yghiC_U2RaM

And like 4 or 5 2010 CVE's but I don't post them! :)

[December 10, 2010 at 10:01 AM](#)

tarball said...

Universal XSS in IE8... <http://p42.us/ie8xss/>

December 10, 2010 at 5:33 PM

Jeremiah Grossman said...



@ydinoul: added #51. thank you

@tarball: great one, #52

December 12, 2010 at 8:55 AM

Soroush Dalili said...

Please look at this:

<http://blog.48bits.com/2010/09/28/iis6-asp-file-upload-for-fun-and-profit/>

I wish it was in English; However, this guy has written about a new technique in IIS6 which is another Microsoft FeaTure-Bug (FeaFlase!!!) :P

/Folder.asp/test.txt
test.txt will be run as a ASP file!

December 13, 2010 at 4:07 AM

G said...

[HTTP://fuzzdb.googlecode.com](http://fuzzdb.googlecode.com)

Open database of attack patterns and predictable resources

December 15, 2010 at 10:43 AM

Aditya K Sood said...



Persistent Cross Interface Attacks -
<http://secniche.blogspot.com/2010/11/malware-paradox-cia-aavar-2010.html>

December 15, 2010 at 2:02 PM

Aditya K Sood said...



Bypassing NoScript 2.0.6 or < - through Union SQL Poisoning using SQLXSSI

<http://www.youtube.com/TheKnock#p/a/u/1/r-kgKNspqjQ>

December 15, 2010 at 2:06 PM

Aditya K Sood said...



Web Widgets - Interface Flaws
<http://www.slideshare.net/adityaks/owasp-app-sec-us-2010>

December 15, 2010 at 2:10 PM

Aditya K Sood said...



Google Chrome Authentication Dialog Spoofing through Realm Manipulation

<http://zeroknock.blogspot.com/2010/08/google-chrome-http-auth-dialog-through.html>

December 15, 2010 at 2:12 PM

Aditya K Sood said...

 Pwning Data-centers by hacking support system suites.
<http://magazine.hitb.org/issues/HITB-Ezine-Issue-004.pdf>
December 15, 2010 at 2:21 PM

Aditya K Sood said...

 Open Redirect Wreck Off - Differential Redirection Attacks
<http://magazine.hitb.org/issues/HITB-Ezine-Issue-002.pdf>
December 15, 2010 at 2:22 PM

Jeremiah Grossman said...

 @Soroush: thank you, added #53.

@SecNiche: thanks for the contribution. I added 3 of the 6 you commented, #54 - #56. The others, while interesting articles, did not appear to be new techniques. More using older techniques, while still valid, to attack more modern systems. Good luck!
December 16, 2010 at 8:21 AM

Aditya K Sood said...

 @Jer Thanks.
December 16, 2010 at 8:33 AM

Collin Jackson said...

 Poisoning proxy caches using Java/Flash/Web Sockets:
<http://www.adambarth.com/experimental/websocket.pdf>
http://news.cnet.com/8301-30685_3-20025272-264.html
December 16, 2010 at 2:54 PM

lava said...

Some more for your consideration:

<http://blog.andlabs.org/2010/12/performing-ddos-attacks-with-html5.html>

<http://blog.andlabs.org/2010/12/cracking-hashes-in-javascript-cloud.html>

<http://blog.andlabs.org/2010/07/shell-of-future-reverse-web-shell.html>

December 17, 2010 at 1:46 AM

lava said...

Some more for your consideration:

<http://blog.andlabs.org/2010/12/cracking-hashes-in-javascript-cloud.html>

<http://blog.andlabs.org/2010/12/performing-ddos-attacks-with-html5.html>

<http://blog.andlabs.org/2010/07/shell-of-future-reverse-web-shell.html>

December 17, 2010 at 1:48 AM

Jeremiah Grossman said...

 @Collin: Thanks! Got you down at #62

@Lava: Added 2 of your three. Excellent work.

Plus I added two more.

December 17, 2010 at 9:52 AM

lava said...

Awesome, thanks :)

December 17, 2010 at 11:28 AM

James Kettle said...



Would my phishing variant qualify?

<http://skeletonscribe.blogspot.com/2010/12/chronofeit-phishing.html>

December 18, 2010 at 3:31 PM

lava said...

Two more suggestions:

1) Getting the cookies using a server-side redirect and JAVA by LeverOne:

<http://sla.ckers.org/forum/read.php?2,35422>

2) doz.me by Ben Schmidt:

<http://spareclockcycles.org/2010/12/19/doz-me-the-evil-url-shortener/>

December 20, 2010 at 8:54 AM

Jeremiah Grossman said...



@albino: thank you, #65

@lava: thanks, but this is too similar to earlier work:

<http://jeremiahgrossman.blogspot.com/2008/04/csrf-ddos-skeleton-in-closet.html>

December 27, 2010 at 3:38 PM

Andrew van der Stock said...



The IIS 5.1 one using alternate data streams is a very, very old attack, but a new form. Appending :\$DATA to filenames has been known for at least a decade.

December 28, 2010 at 2:26 AM

Adam Baldwin said...



While this is very specific to the Django web framework. It's essentially blind injection but at the ORM level.

<http://evilpacket.net/2010/dec/22/information-leakage-django-administrative-interfac/>

December 29, 2010 at 1:17 AM

Anonymous said...

SQL injection filter evasion by Reiners:

<http://websec.files.wordpress.com/2010/11/sqliz.pdf> (slides)

<https://websec.wordpress.com/2010/12/04/sqli-filter-evasion-cheat-sheet-mysql/> (cheatsheet)

December 31, 2010 at 5:29 AM

Anonymous said...

Interesting one if it's not too late:
<http://briandefrancesco.com/?p=40>

January 3, 2011 at 5:32 PM

Soroush Dalili said...

Probably it's too late but still good to be in the list for the future reference:

-

Breaking HTML parsers for fun
<http://www.thespanner.co.uk/2010/11/25/breaking-html-parsers-for-fun/>

-

setTimeout and setInterval
<http://www.thespanner.co.uk/2010/09/10/settimeout-and-setinterval/>

-

JSReg bypasses:
<http://www.thespanner.co.uk/2010/10/31/jsreg-bypasses/>
<http://code.google.com/p/jsreg/wiki/Exploits>
http://rgaucher.info/planet/The_Spanner/2010/11/07/Soroush_Dalili_breaks_JSReg_again

-

xss - test encodings and character transformations to find XSS hotspots
<http://xss.codeplex.com/>
<http://www.lookout.net/2010/12/20/list-of-characters-for-testing-unicode-transformations-and-best-fit-mapping-to-dangerous-ascii/>

-

Facebook Redirect Link - New Bypass Method - "://" after the domain name
<http://soroush.secproject.com/blog/2010/12/facebook-redirect-link-new-bypass-method-%E2%80%93-%E2%80%9C%E2%80%9D-after-the-domain-name/>

-

:)

January 4, 2011 at 5:54 AM

zdx said...

How come the best server side findings and techniques (Struts/JBoss/Spring) from Meder didn't make into the list? . Also, where is the Java Trusted Method Chaining by Sami Koivu?

You might argue with the "no CVE rule" but there is no clear cut between techniques and bug in these cases actually. For example, in order to have a successful attack on ASP.NET, POET need to exploit bug of ASP.NET implementation/configuration but you have POET on the list]

January 4, 2011 at 10:22 PM

Jeremiah Grossman said...

@zdx: "making the list" is subject to me finding it through my personal efforts or people submitting them on their own, with some light validation of course. That's a big reason for the effort, to capture everything that's been learned over the past year and not have it get lost in the ether as has been the problem in years past.

If you can supply the best reference links to the attacks you mentioned, I'd be very happy to review them for inclusion on the big list. The CVE mention was just an indication that we want "new" technique, not individual bug instances.

January 5, 2011 at 9:07 AM

shinto143 said...



I like to add a vulnerability which I found during a gray box testing..
Its a type of back refresh attack. For mitigating back refresh attack we use a 302 redirect in successful operation. But in one of my app i tested there was a password policy saying password cant change withing 30 days. attack is If the user try to change the password withing 30 days it will respond with a 200 ok response. For a successful change adversary cant do anything..
But if the password changing failed due to some reason(password policy, new & conform password mismatch.. etc)attacker can exploit the back refresh option of the browser and can capture the request in proxy.

January 6, 2011 at 10:50 PM

shinto143 said...



New google hacking techniques(Type the commands in google search engine.):

1. accessing public security cameras-
inurl:"viewframe?mode-motion"
intitle:"Live View / - AXIS"

2. Un spider sites:
"robots.txt" "disallow:" filetype:txt

3. Front page user info-
inurl:_vti_pvt "service.pwd"

4. PHP Photo album-
inurl:"phphotoalbum/upload"

5. VNC user info-
"vnc desktop" inurl:5800

6. Network printer-
inurl:"port_255" -htm

7.PHP admin account-
intitle:phpMyAdmin "Welcome to phpMyAdmin*****" "running on*as root@*"

January 6, 2011 at 11:10 PM

Marcus Niemietz said...



I would like to propose my seminar work "UI Redressing: Attacks and Countermeasures Revisted".

URL: <http://ui-redressing.mniemietz.de/>

Thanks in advance.

January 7, 2011 at 5:52 AM

Jeremiah Grossman said...



@shinto143: The back button attack you describe, cool as it is, has actually been documented and demoed in years past. Don't have time to find the reference at the moment. And your Google Hacking concept has been around for a while, I don't see any "new techniques" described.

@Marcus Niemietz: thanks for the submission. I can certainly add it to the big list, but can't get it voted on now since the process has commenced.

January 7, 2011 at 9:11 AM

Anonymous said...

You guys shouldn't be posting advice to hack.

August 13, 2012 at 9:46 AM

[Post a Comment](#)

[Newer Post](#)

[Home](#)

[Older Post](#)

Subscribe to: [Post Comments \(Atom\)](#)

Picture Window theme. Powered by Blogger.

This site uses cookies from Google to deliver its services and to analyse traffic. Your IP address and user agent are shared with Google, together with performance and security metrics, to ensure quality of service, generate usage statistics and to detect and address abuse.

[LEARN MORE](#) [GOT IT](#)